

API Test Log

Test ID	Vulnerability	Severity	Target Endpoint
008	BOLA (IDOR)	Critical	/api/users
009	GraphQL Injection	High	/graphql

50-Word API Testing Summary

The API security assessment identified critical Broken Object Level Authorization and GraphQL injection vulnerabilities. Unauthorized access to user data was possible by manipulating object IDs and GraphQL queries. Missing access controls and insufficient authorization validation expose sensitive information, highlighting the need for strict authorization checks and query validation.

API Security Testing Checklist (DVWA API)

Enumerate API Endpoints

- ☐ Configure browser to use Burp Suite proxy
- ☐ Capture API traffic using Burp Proxy → HTTP history
- ☐ Identify all accessible API endpoints
- ☐ Note HTTP methods used (GET, POST, PUT, DELETE)
- ☐ Identify parameters, headers, and authentication tokens
- ☐ Document discovered endpoints with screenshots

Test for BOLA / IDOR (Using Burp Suite)

- ☐ Identify object-based endpoints (e.g., `/api/users?id=`)
- ☐ Send request to Burp Repeater
- ☐ Modify object identifiers (user ID, account ID, etc.)
- ☐ Replay modified requests
- ☐ Verify if unauthorized data is returned

- ☐ Capture request and response evidence
- ☐ Mark vulnerability severity based on impact

Fuzz GraphQL Queries (Using Postman)

- ☐ Identify GraphQL endpoint (e.g., `/graphql`)
- ☐ Send a valid baseline GraphQL query
- ☐ Enumerate available fields and objects
- ☐ Modify queries to access restricted fields
- ☐ Test for excessive data exposure
- ☐ Observe error handling and response behavior
- ☐ Capture successful exploitation screenshots

Final Verification

- ☐ All findings documented with screenshots
- ☐ Vulnerabilities mapped to OWASP API Top 10
- ☐ Severity levels assigned correctly
- ☐ Summary written and reviewed